NovaPay Zero-Downtime CI/CD Pipeline

Technology Risk Committee Presentation

DevOps & Cloud Engineer Assessment | Banking CI/CD Architecture

- Objective: transform manual SSH releases into a compliant, automated, auditable DevSecOps platform.
- Scope: pipeline design, IaC, deployment strategy, rollback, observability, incident response, and regulatory evidence.

Prepared for TRC review and simulated approval.

Current State Problem

• Manual SSH deployments create high operational risk and poor traceability.

• NovaPay baseline includes fortnightly releases, 4.5-hour MTTR, zero automated compliance scanning, and open audit non-conformances.

• Payment workloads require high availability, fast recovery, and controlled change management.

• Emergency hotfixes must be safe without bypassing security or approval gates.

Target Outcomes

- Minimum eight-stage CI/CD pipeline with fail-closed quality gates.
- Commit-to-production target below two hours while preserving production safety.
- Blue-green and canary deployment with automated rollback.
- Zero-downtime database migration using Expand-Migrate-Contract.
- Complete audit evidence for every production release.

Eight-Stage Pipeline Architecture

1	Source & Build	GitHub Actions, Docker
2	Testing	Unit, integration, contract
3	Security	SAST, dependency scan, SBOM
4	Compliance	OPA, RBI-aligned controls, PCI-DSS, SoD
5	DAST	OWASP ZAP runtime testing
6	Artifact Validation	Container scan and immutable digest
7	Promotion	Dev -> Staging -> Pre-Prod -> Prod
8	Verification	Monitoring, rollback, evidence

Security and Compliance Gates

- SAST: 0 critical vulnerabilities; high findings require remediation or approved exception.
- Dependency and container scans: 0 critical CVEs; SBOM generated and archived.
- DAST: 0 critical/high findings for production promotion.
- OPA/Rego policies enforce Kubernetes security, PCI-DSS gates, and Segregation of Duties.
- Exception workflow is time-bounded, auditable, and requires independent approval.

Regulatory Control Mapping

Control Area	NovaPay Implementation
Change governance	Pipeline approvals, CAB evidence, production release gates
Access control	RBAC, controlled service accounts, no direct production deployment
Security testing	SAST, DAST, dependency and container scanning
Auditability	Commit SHA, image digest, approvals, scan reports, deployment records
Incident management	SEV workflow, rollback automation, postmortem evidence
Third-party risk	SBOM, license controls, vendor/dependency scanning

Note: exact RBI subsection numbering is handled in ERRATA to avoid unsupported regulatory references.

Zero-Downtime Deployment Strategy

- Blue-green keeps previous stable environment available for immediate fallback.
- Canary gradually exposes traffic through 1-2%, 5-10%, 25-50%, then 100% rollout.
- Canary promotion uses latency/error-rate thresholds and statistical comparison against production baseline.
- Redis-backed session continuity prevents customer session loss.
- Connection draining protects in-flight payment transactions during traffic switch.

Database Migration Strategy

- EXPAND: add backward-compatible columns/tables while old and new app versions both work.
- MIGRATE: backfill using idempotent, restartable, throttled batch jobs.
- VALIDATE: compare row counts, nulls, payment references, latency, and transaction health.
- CONTRACT: remove legacy schema only after validation, bake period, and separate approval.
- Abort migration if query latency increases by more than 20%.

Rollback Strategy

- Category A: immediate automated rollback under 60 seconds.
- Triggers: 5xx >5% for 60s, 3 health failures, OOM, CrashLoopBackOff, DB pool exhaustion.
- Category B: escalated rollback under 15 minutes for latency, burn-rate, transaction, CPU/memory regressions.
- Category C: manual decision for gradual degradation or customer-reported issues.
- Workflow: Detect -> Correlate -> Freeze -> Rollback -> Verify -> Notify -> Incident -> Postmortem.

Observability and DORA Metrics

• Engineering dashboard: real-time service health, deployment, and rollback signals.

• Management dashboard: DORA metrics, lead time, failure rate, MTTR, deployment frequency.

• Regulatory dashboard: compliance gate results, approval evidence, audit readiness.

• DORA targets: multiple deployments per day, lead time <1 hour, change failure <5%, MTTR <1 hour.

• Alerts route by severity with escalation and incident workflow integration.

Infrastructure as Code

- Terraform modules: VPC, EKS, ECR, Observability.
- Helm chart: Deployment, Service, ServiceAccount, probes, resource limits, non-root security context.
- ArgoCD application: GitOps sync from repository path pipeline/helm.
- Prometheus alert rules and rollback script are included under monitoring/ and pipeline/scripts/.
- Terraform validate, Helm lint/template, and OPA policy checks passed.

Friday 5 PM Incident Simulation

- Scenario: critical hotfix bypassed staging and reached production canary.
- Alerts: HTTP 500 at 12%, PostgreSQL pool exhaustion, payment-gateway timeout at 35%.
- Severity: SEV-1 because payment processing was customer-impacting.
- Action: freeze canary, correlate with deployment, rollback, verify recovery, open postmortem.
- Root cause: Stage 7 environment promotion gate was bypassed.

Risk Reduction Summary

Risk	Control Implemented
Manual deployment error	GitHub Actions, ArgoCD, immutable artifacts
Unsafe code release	SAST, DAST, tests, contract testing
Compliance failure	OPA/Rego, PCI-DSS gates, audit evidence
Production outage	Blue-green/canary, rollback, health probes
Database downtime	Expand-Migrate-Contract with latency abort
Unauthorized promotion	RBAC, SoD, approval gates

Validation Evidence

- Python tests: 9 passed.
- Docker build: passed; /health and /ready returned HTTP 200.
- Terraform: fmt, init -backend=false, validate passed.
- Helm: lint passed with 0 chart failures; template rendered successfully.
- OPA/Rego: all policy files passed opa check.
- Rollback script: bash syntax validation passed.

Implementation Timeline

Phase	Status
Pipeline architecture and stage specifications	Complete
Deployment strategies and database migration	Complete
Compliance gates and policy-as-code	Complete
Environment promotion and rollback design	Complete
Runbook, observability, dashboards	Complete
Incident simulation and postmortem	Complete
TRC presentation and final submission package	Ready for review

TRC Decision Request

- Approve the NovaPay zero-downtime CI/CD architecture for simulated regulated banking deployment.
- Approve fail-closed security, compliance, and environment-promotion controls.
- Approve automated rollback as mandatory for production progressive delivery.
- Approve Terraform, Helm, ArgoCD and OPA as the delivery foundation.
- Approve continued validation through incident drills, postmortems and compliance evidence review.

Q&A; Preparation: evidence is available in README, ERRATA, docs/, pipeline/, monitoring/, dashboards/, and Git history.